

Section 1: Authentication and Passwords

This section defines credential controls for all employees, contractors and vendors.

Password length: every password must contain a minimum of 14 characters.

User password rotation: user account passwords must be changed every 90 days.

Service account secret rotation: secrets used by service accounts must be rotated every 180 days.

Password reuse: the last 12 passwords cannot be reused.

Multi-factor authentication is required for all accounts. Administrators must additionally use hardware security keys.

Account lockout: an account is locked after 5 failed login attempts and the lockout lasts 30 minutes.

Section 2: Remote Access and Devices

This section covers how staff may connect to company systems from outside the office.

A VPN is required to reach internal systems from outside the corporate network. Split tunneling is prohibited.

Remote sessions are terminated after 15 minutes of inactivity (session idle timeout).

All company laptops must use full-disk encryption with AES-256.

Personal devices must be enrolled in MDM (mobile device management) before they can access company email.

A lost or stolen device must be reported to IT within 2 hours of discovery.

The guest Wi-Fi network is isolated from the corporate network.

Section 3: Incident Response

Security incidents are classified as SEV1 (critical), SEV2 (high) or SEV3 (moderate).

For a SEV1 incident the response team must acknowledge within 15 minutes and executives must be notified within 1 hour.

For a SEV2 incident the response team must respond within 4 hours.

A post-incident review must be completed within 5 business days of closing an incident.

Personal data breaches must be reported to the regulator within 72 hours of discovery.

All incidents are reported through the 24x7 Security Operations Center hotline.

Section 4: Data Classification and Retention

Data is classified as Public, Internal, Confidential or Restricted.

Financial records are retained for 7 years.

Employee records are retained for 5 years after termination of employment.

System logs are retained for 12 months, while security audit logs are retained for 24 months.

Backups run as daily incrementals and weekly full backups, and backups are retained for 35 days.

Restricted data must be encrypted at rest with AES-256 and in transit with TLS 1.2 or higher.

Section 5: Compliance and Vendors

Security awareness training is mandatory and must be completed within 30 days of hire, then repeated annually.

An external firm performs a penetration test once per year.

A vendor risk assessment is required before onboarding any vendor. Critical vendors are reassessed every 12 months.

Exceptions to this policy require written approval from the CISO and are valid for a maximum of 6 months.

Internal audits are performed quarterly.